Acceso Remoto Seguro para The Store

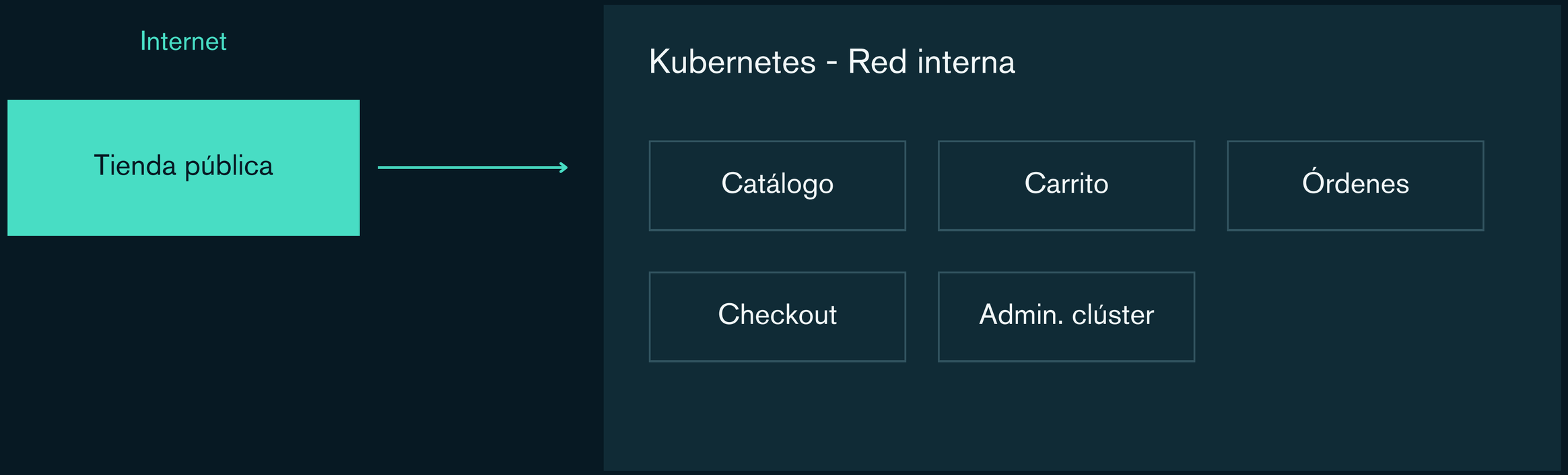
Redes de Información - TP Especial

ITBA - 2C 2026 - Grupo 7
Thibault Fricot - 69590
Joaquín Nicolás Yulán Lucioli (60568)
Federico Etchegorry - 63175



The Store

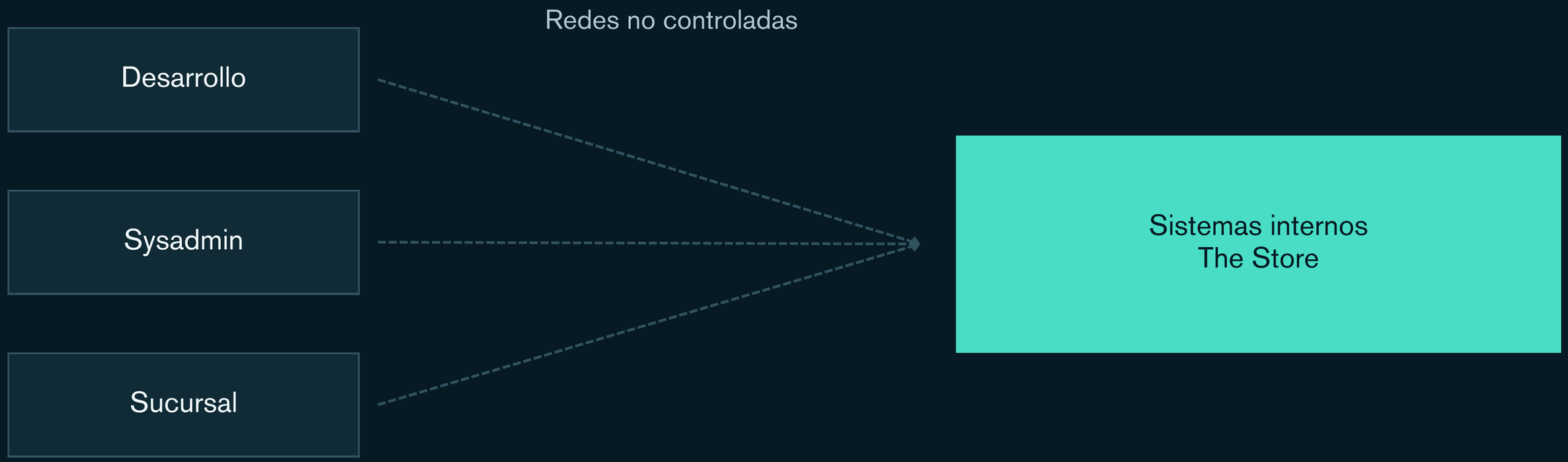
Un e-commerce con cinco microservicios sobre Kubernetes.



Sólo se expone la tienda y el resto permanece dentro de la Red Interna.

El problema de negocio

¿Cómo se puede trabajar desde afuera sin abrir la red de la empresa?



¿Cómo habilitar acceso sin perder control?

Los riesgos que se busca eliminar

Credencial robada

Acceso indebido → datos expuestos.

Permisos excesivos

Una cuenta comprometida → más sistemas afectados.

Acceso sin baja

Una salida del equipo → una puerta que sigue abierta.



Una puerta de entrada cifrada

Una llave por persona con permisos según el rol.

Cifrar

Proteger el tránsito

Limitar

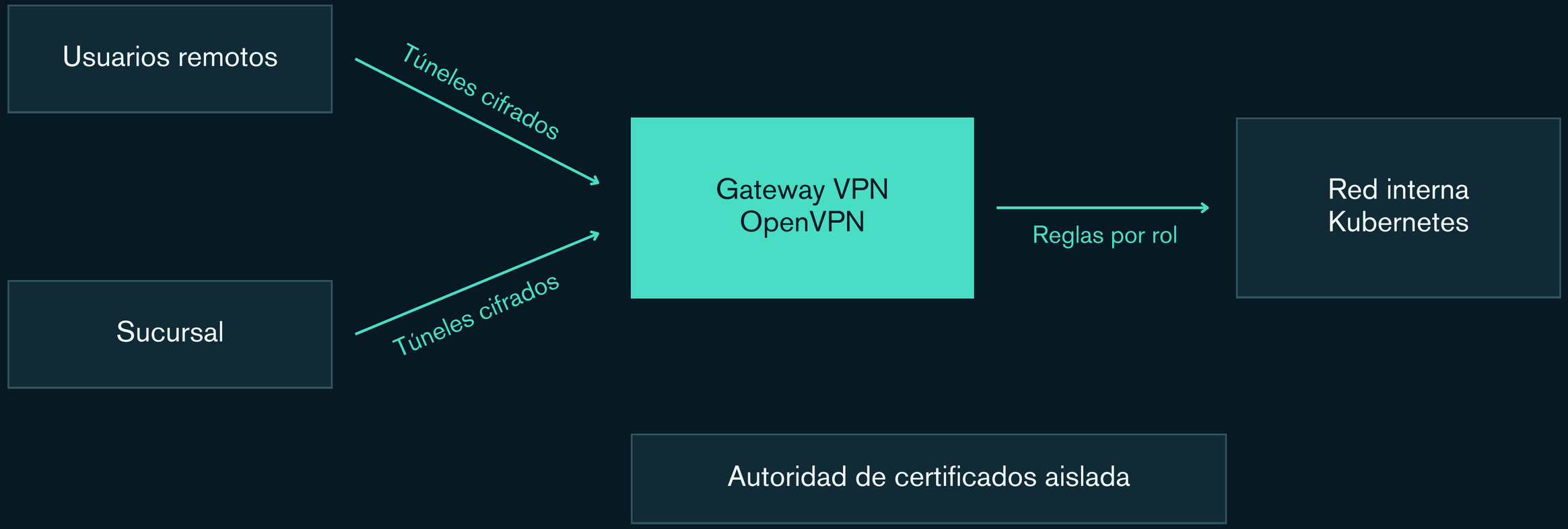
Habilitar sólo lo necesario

Identificar

Saber quién entra

¿Cómo funciona la solución?

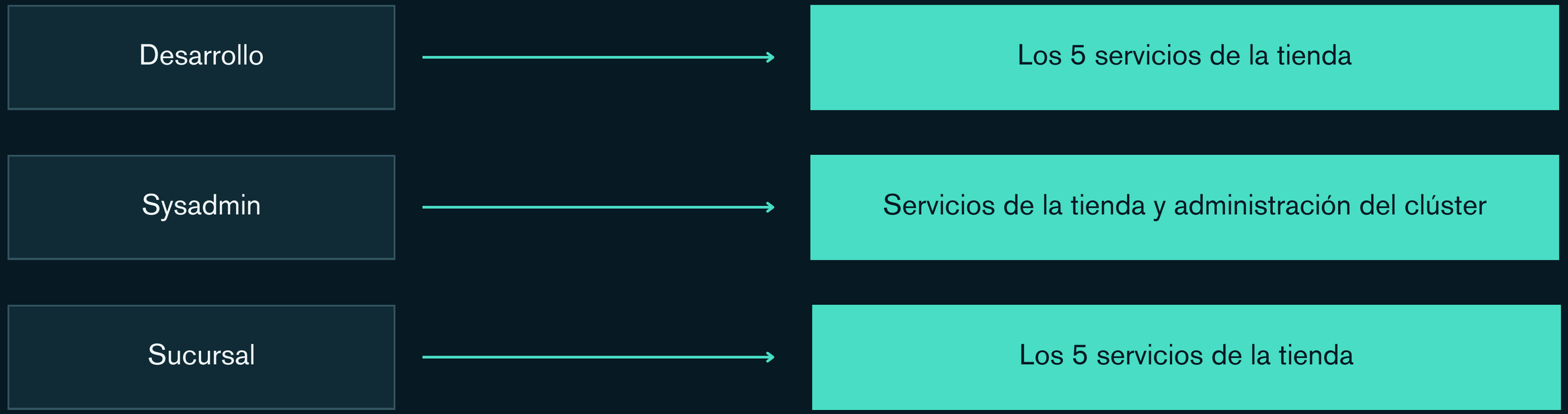
Todo acceso remoto pasa por el gateway VPN.



Emite y revoca llaves sin transporte de tráfico.

Cada rol ve sólo lo necesario

Estar dentro de la VPN no implica tener acceso a todo.



Mínimo privilegio se traduce en menor alcance y daño.

Altas y bajas

Los accesos individuales se pueden entregar, cambiar y retirar.



Identidad y certificado propios

Rol y accesos autorizados

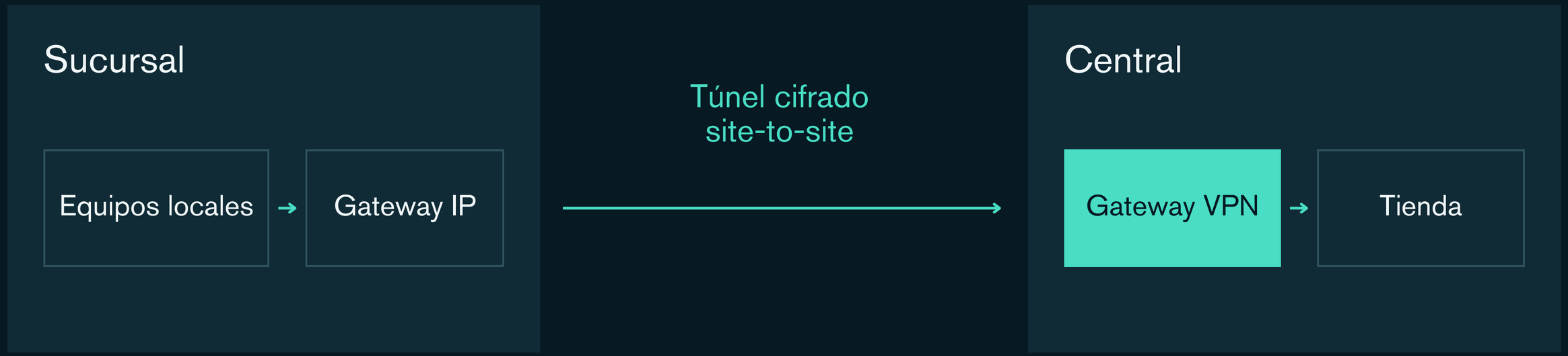
Conexión y logs

Revocación y corte de la sesión en curso

Si hay una salida del equipo se revoca esa llave, sin afectar al resto.

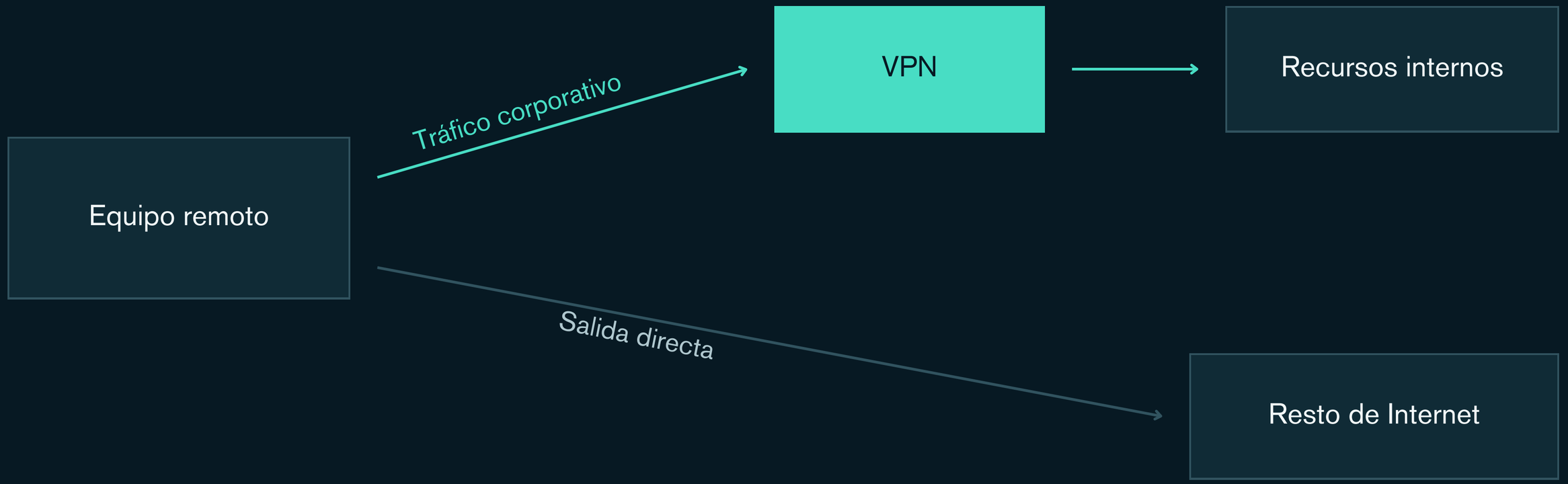
Una sucursal conectada sin instalar nada

No hay un cliente VPN en cada equipo, el túnel VPN lo crean los Gateways al conectarse a ellos.



Seguro sin frenar al equipo

Split Tunnel : Por la VPN viaja sólo el tráfico dirigido a los recursos internos.



Costo y operación

100% Gratis

OpenVPN no tiene costos por usuario.

Despliegue automatizado

Scripts reproducibles sobre servidores Ubuntu estándar en VMs.



Se necesitan servidores y que una persona o equipo que se encargue de las altas y bajas.

Lo que vamos a demostrar

CU1

Puerta cerrada

Sin VPN, la red interna es invisible.

CU2

Alta de usuario

Conexión desde Windows y uso de la tienda.

CU3

Permisos por rol

Desarrollo vs. sysadmin: cada uno, sólo lo suyo.

CU4

Baja inmediata

Se corta la sesión y no puede volver.

CU5

Tráfico ilegible

En la red pública sólo se ve tráfico cifrado.

CU6

Sucursal

Accede a la tienda sin cliente VPN.

CU1

Resumen de las pruebas desde la WAN

```
>>> 1. Sin túnel, como un atacante en la WAN
[cli-adm] $ systemctl stop openvpn-client@the-store; …
eth0             UP             203.0.113.51/24
    [OK] cli-adm no tiene interfaz de túnel

>>> 2. Escaneo TCP a gw-vpn (203.0.113.10)
[cli-adm] $ nmap -Pn -sS -p 22,53,80,443,1194,6443 …
22/tcp   filtered ssh
53/tcp   filtered domain
80/tcp   filtered http
443/tcp  filtered https
1194/tcp filtered openvpn
6443/tcp filtered sun-sr-https
    [OK] Los seis puertos están filtrados: no hay respuesta ni RST
    [OK] gw-vpn registró el descarte (input) de 203.0.113.51 hacia 203.0.113.10

>>> 3. Sondeo UDP al puerto 1194 (sin la clave tls-crypt)
1194/udp open|filtered openvpn
[cli-adm] $ echo -n PROBE | socat -T 1 - UDP4:203.0.113.10:1194 | wc -c
0
    [OK] OpenVPN no contesta sin tls-crypt (0 bytes)

>>> 4. Sin ruta a la red interna (10.10.10.5)
10.10.10.5:80 bloqueado
10.10.10.5:22 bloqueado
10.10.10.5:6443 bloqueado
    [OK] Ningún puerto de 10.10.10.5 es alcanzable sin ruta

>>> 5. Ruta manual a la LAN a través del gateway
[cli-adm] $ ip route add 10.10.0.0/16 via 203.0.113.10; …
10.10.10.5 via 203.0.113.10 dev eth0 src 203.0.113.51 uid 0
10.10.10.5:80 bloqueado
10.10.10.5:22 bloqueado
10.10.10.5:6443 bloqueado
    [OK] La ruta manual apunta al gateway
    [OK] Ni siquiera con la ruta manual se alcanza la LAN
[gw-vpn] $ dmesg | grep 'the-store forward drop' | …
the-store forward drop SRC=203.0.113.51 DST=10.10.10.5 PROTO=TCP SPT=42906 DPT=6443
    [OK] gw-vpn registró el descarte (forward) de 203.0.113.51 hacia 10.10.10.5

>>> 6. Qué escucha gw-vpn y con qué usuario corre OpenVPN
    [OK] OpenVPN escucha solo en la IP de la WAN, UDP/1194
    [OK] sshd escucha en la red de gestión (192.168.100.1:22)
    [OK] sshd no escucha en otras interfaces
    [OK] OpenVPN corre sin privilegios (usuario nobody)

>>> 7. Política del firewall de gw-vpn (nftables)
    [OK] La cadena input descarta por defecto
    [OK] La cadena forward descarta por defecto

Resultado CU1: 14 correctas, 0 fallidas
```

CU2

Resumen de las pruebas del desarrollador (dev-02)

```
>>> 1. Alta en la CA: certificado y CCD de dev-02
subject=CN = dev-02
issuer=CN = The Store VPN CA
notBefore=Nov  4 22:35:28 2026 GMT
notAfter=Nov  4 22:35:28 2027 GMT
ifconfig-push 10.8.0.11 255.255.255.0
push "route 10.10.10.5 255.255.255.255"
    [OK] El certificado es de dev-02
    [OK] El CCD le fija la IP 10.8.0.11
    [OK] El CCD solo le da ruta a 10.10.10.5/32

>>> 2. Perfil .ovpn unificado (sin imprimir las claves)
    [OK] El perfil incluye tls-crypt

>>> 3. Cliente Windows: IP del túnel y rutas
IPAddress      : 10.8.0.11
    [OK] Windows tiene la IP fija del perfil (10.8.0.11) en el adaptador del túnel
       10.10.10.5  255.255.255.255         10.8.0.1        10.8.0.11    225
    [OK] Solo 10.10.10.5 se enruta por el túnel (split-tunnel)

>>> 4. DNS del cliente: política NRPT
Namespace   : .the-store.internal
NameServers : 10.8.0.1
    [OK] Solo la zona .the-store.internal se manda al DNS 10.8.0.1

>>> 5. DNS interno: resuelve la tienda y rechaza dominios externos
Name:    ui.the-store.internal
Address:  10.10.10.5
    [OK] ui.the-store.internal resuelve a 10.10.10.5
*** UnKnown can't find example.com: Query refused
    [OK] El DNS interno rechaza dominios externos

>>> 6. gw-vpn ve al cliente con su IP fija
admin-01,203.0.113.51:40512,10.8.0.20
gw-sucursal,203.0.113.20:54878,10.8.0.30
dev-02,203.0.113.50:52243,10.8.0.11
    [OK] gw-vpn tiene a dev-02 conectado con 10.8.0.11
    [OK] El servidor verificó el certificado de dev-02

>>> 7. La aplicación, por nombre y a través del túnel
    [OK] El catálogo devuelve productos
    <title>Demo Store</title>
    [OK] La UI devuelve su página
HTTP 201
    [OK] El carrito acepta el ítem
[{"itemId":"a1258cd2-176c-4507-ade6-746dab5ad625","quantity":2,"unitPrice":199}]
    [OK] El carrito devuelve el ítem agregado

Resultado CU2: 15 correctas, 0 fallidas
```

CU3

Resumen de las pruebas: mismo destino, permisos distintos

```
>>> 1. Qué decide el rol: IP fija por CCD y reglas nftables por rango
    [OK] El firewall deja a dev (.10-.19) solo el puerto 80 del nodo
    [OK] El firewall deja al sysadmin (.20-.29) los puertos 22, 80 y 6443
    [OK] Todo lo demás se descarta y se registra

>>> 2. Desarrollador (dev-02): el Ingress (80) responde; SSH (22) y API de Kubernetes (6443) no
10.10.10.5:80 ABIERTO
10.10.10.5:22 bloqueado
10.10.10.5:6443 bloqueado
    [OK] 10.10.10.5:80 (Ingress) está abierto para el rol dev
    [OK] 10.10.10.5:22 (SSH) está bloqueado para el rol dev
    [OK] 10.10.10.5:6443 (API de Kubernetes) está bloqueado para el rol dev
the-store forward drop SRC=10.8.0.11 DST=10.10.10.5 PROTO=TCP SPT=52018 DPT=22
the-store forward drop SRC=10.8.0.11 DST=10.10.10.5 PROTO=TCP SPT=52019 DPT=6443
    [OK] gw-vpn registró el descarte (forward) de 10.8.0.11 hacia 10.10.10.5

>>> 3. Desarrollador: los cinco microservicios responden por el Ingress
    [OK] Los cinco servicios responden HTTP 200

>>> 4. Desarrollador: sin acceso al gateway (SSH y gestión)
10.8.0.1:22 bloqueado
    [OK] El SSH del gateway (10.8.0.1:22) está bloqueado para el rol dev

>>> 5. Sysadmin (admin-01): mismo destino, puertos 80, 22 y 6443 abiertos
tun0             UNKNOWN        10.8.0.20/24
10.10.10.5:80 ABIERTO
10.10.10.5:22 ABIERTO
10.10.10.5:6443 ABIERTO
    [OK] 80, 22 y 6443 están abiertos para el sysadmin

>>> 6. Sysadmin: administra el nodo por SSH
k8s-node
the-store-control-plane: Up 33 minutes
    [OK] Entra al nodo k8s-node por SSH
    [OK] Administra el cluster Kind (docker ps)

>>> 7. Sysadmin: con el token acotado del kubeconfig lista pods y lee logs
    [OK] Lista los 5 pods de the-store en Running
    [OK] RBAC le permite leer los logs
    [OK] Los logs no vienen vacíos

>>> 8. Sysadmin: mínimo privilegio (RBAC) en Kubernetes
list pods -n the-store                          yes
get secrets -n the-store                        no
delete pods -n the-store                        no
create pods --subresource=exec -n the-store     no
list pods -n kube-system                        no
    [OK] No puede leer Secrets, borrar pods, hacer exec ni ver kube-system
    [OK] Leer Secrets devuelve Forbidden
    [OK] Listar pods de kube-system devuelve Forbidden
    [OK] Borrar pods devuelve Forbidden

>>> 9. Sysadmin: no llega a la administración del gateway ni de la CA
10.8.0.1:22 bloqueado
192.168.100.20:22 bloqueado
    [OK] El sysadmin no alcanza ni gw-vpn ni la CA

Resultado CU3: 20 correctas, 0 fallidas
```

CU4

Resumen de las pruebas: revocación en caliente de dev-02

```
>>> 1. Antes: tres clientes conectados y el sysadmin operando
admin-01,203.0.113.51:40512,10.8.0.20
gw-sucursal,203.0.113.20:54878,10.8.0.30
dev-02,203.0.113.50:52243,10.8.0.11
    [OK] Están conectados dev-02, admin-01 y gw-sucursal
00:28:30
carts-89cc64d59-xw64t       1/1   Running   2 (33m ago)   54m
catalog-86bd79fb8-54j8w     1/1   Running   2 (33m ago)   54m
    [OK] El sysadmin lista pods

>>> 2. En la CA: revocar el certificado (la CRL cambia solo en la CA)
Revoking Certificate EBAB18C4FFBC44D0838844CF548783FB.
Database updated
CRL valid until Dec  5 00:28:31 2026 GMT.
R       271104223528Z   2611050028830Z   EBAB18C4FFBC44D0838844CF548783FB       unknown /CN=dev-02
    [OK] La CA registró dev-02 como revocado
    La CRL todavía no llegó a gw-vpn: la sesión sigue en pie
    [OK] dev-02 sigue conectado hasta que se publique la CRL

>>> 3. Publicar la CRL en gw-vpn: se instala y se corta la sesión del revocado
CRL installed
dev-02: session ended
    [OK] La CRL quedó instalada en gw-vpn
    [OK] Se cortó la sesión activa de dev-02

>>> 4. Después: dev-02 desaparece, los demás siguen conectados y operando
admin-01,203.0.113.51:40512,10.8.0.20
gw-sucursal,203.0.113.20:54878,10.8.0.30
    [OK] dev-02 ya no está conectado
    [OK] Siguen conectados: admin-01 gw-sucursal
00:28:43
carts-89cc64d59-xw64t       1/1   Running   2 (33m ago)   54m
catalog-86bd79fb8-54j8w     1/1   Running   2 (33m ago)   54m
    [OK] La sesión del sysadmin siguió funcionando
Windows -> ui.the-store.internal: HTTP 000
    [OK] Windows ya no llega a la tienda (HTTP 000: sin conexión)

>>> 5. El certificado revocado intenta reconectar: gw-vpn lo rechaza por la CRL
intento de reconexión con dev-02.ovpn terminado
Nov 05 00:28:59 gw-vpn openvpn[822]: 203.0.113.51:56989 Sent fatal SSL alert: certificate revoked
    [OK] gw-vpn rechazó la conexión: certificate revoked (dev-02)
    La revocación corta el acceso por la VPN: no invalida el token de Kubernetes ni la clave
SSH del usuario
    Para dejar el laboratorio limpio: bash setup-lab.sh reset-demo

Resultado CU4: 11 correctas, 0 fallidas
```

CU5

Resumen de las pruebas: confidencialidad, túnel dividido y DNS interno

```
>>> 1. Captura simultánea en gw-vpn (WAN, LAN y túnel) mientras Windows usa la tienda y resuelve nombres
Name                      Type IPAddress
----                      ---- ---------
orders.the-store.internal    A 10.10.10.5

Name       Type IPAddress
----       ---- ---------
google.com    A 142.251.128.78
    [OK] El nombre interno se resuelve a 10.10.10.5

>>> 2. WAN: datagramas UDP cifrados, sin nombres ni HTTP legibles
udp=123 nombres=0
00:38:01.666170 IP 203.0.113.50.53367 > 203.0.113.10.1194: UDP, length 189
00:38:01.666665 IP 203.0.113.50.53423 > 203.0.113.10.1194: UDP, length 189
    [OK] La WAN solo muestra UDP cifrado, sin ningún nombre legible

>>> 3. LAN: el mismo tráfico, ya descifrado por el gateway
00:38:03.889286 IP 10.10.0.1.61411 > 10.10.10.5.80: Flags [P.], seq 1:86, ack 1, win 255, length 85: HTTP: GET / HTTP/1.1
Host: ui.the-store.internal
00:38:03.944079 IP 10.10.10.5.80 > 10.10.0.1.61411: Flags [P.], seq 1:4158, ack 86, win 502, length 4157: HTTP: HTTP/1.1 200 OK
    [OK] En la LAN se lee la petición HTTP en claro
    El origen en eth1 es 10.10.0.1: gw-vpn hace SNAT hacia la LAN. El cifrado llega hasta el gateway; el HTTP interno va en claro.

>>> 4. Túnel dividido: la ruta por defecto de Windows no pasa por la VPN, solo 10.10.10.5/32
          0.0.0.0          0.0.0.0      192.168.1.1     192.168.1.65     45
    [OK] La ruta por defecto no apunta al gateway de la VPN (10.8.0.1)
       10.10.10.5  255.255.255.255         10.8.0.1        10.8.0.11    225

>>> 5. DNS dividido: por el túnel solo entran consultas de la zona interna
      1 AAAA? ui.the-store.internal.
      1 A? demo125.the-store.internal.
      1 A? orders.the-store.internal.
      3 A? ui.the-store.internal.
    [OK] La consulta del nombre interno entró por el túnel
    [OK] google.com no pasó por el túnel: Windows lo resolvió con su DNS local

Resultado CU5: 6 correctas, 0 fallidas
```

CU6

Resumen de las pruebas: conexión de la sucursal (site-to-site)

```
>>> 1. gw-sucursal mantiene su túnel permanente con gw-vpn
admin-01,203.0.113.51:33647,10.8.0.20
gw-sucursal,203.0.113.20:57574,10.8.0.30
dev-02,203.0.113.50:53367,10.8.0.11
    [OK] gw-sucursal está conectada con la IP fija 10.8.0.30
172.16.20.0/24 via 10.8.0.2 dev tun0
--- ccd/gw-sucursal
iroute 172.16.20.0 255.255.255.0
    [OK] gw-vpn enruta 172.16.20.0/24 por el túnel
    [OK] El CCD declara la LAN de la sucursal (iroute)

>>> 2. gw-sucursal reenvía sin NAT y solo deja pasar el Ingress
reglas NAT en gw-sucursal: 0
iifname "eth1" oifname "tun0" ip saddr 172.16.20.0/24 ip daddr 10.10.10.5 tcp dport 80 accept
    [OK] gw-sucursal no hace NAT
    [OK] Solo reenvía 172.16.20.0/24 hacia 10.10.10.5:80

>>> 3. host-suc (172.16.20.10) sin cliente VPN: usa a gw-sucursal como puerta de enlace y
DNS, llega a los cinco servicios y no al SSH ni a la API
eth0             UP             172.16.20.10/24
sin proceso openvpn
ui        10.10.10.5   HTTP 200
carts     10.10.10.5   HTTP 200
orders    10.10.10.5   HTTP 200
catalog   10.10.10.5   HTTP 200
checkout  10.10.10.5   HTTP 200
10.10.10.5:22 bloqueado
10.10.10.5:6443 bloqueado
172.16.20.1:22 bloqueado
    [OK] No corre ningún cliente OpenVPN
    [OK] Los cinco servicios resuelven a 10.10.10.5 y responden HTTP 200
    [OK] Están bloqueados 10.10.10.5:22, 10.10.10.5:6443 y 172.16.20.1:22

>>> 4. Capturas en gw-vpn: entre los gateways solo UDP cifrado; dentro del túnel se conserva
el origen de la sucursal
udp=112 nombres=0
00:39:01.403102 IP 203.0.113.20.57574 > 203.0.113.10.1194: UDP, length 102
00:39:01.403374 IP 203.0.113.10.1194 > 203.0.113.20.57574: UDP, length 118
    [OK] La WAN solo muestra UDP cifrado, sin ningún nombre legible
00:39:01.409814 IP 172.16.20.10.50014 > 10.10.10.5.80: Flags [P.], seq 1:89, ack 1, win 502,
options [nop,nop,TS val 265
Host: ui.the-store.internal
    [OK] En tun0 se ve el origen real de la sucursal (172.16.20.10), sin NAT en gw-sucursal

Resultado CU6: 10 correctas, 0 fallidas
```

Demo en vivo

Límites y próximos pasos

El POC resuelve

Acceso remoto cifrado.
Permisos por rol y revocación.
Conexión de sucursal.

Valida el funcionamiento, no la escala.

Producción requiere

Credenciales de admin por persona.
MFA y gateway redundante.
Monitoreo y alertas.

Integración con el directorio de usuarios.

Conclusiones

- **Superficie de ataque WAN reducida**: El gateway no responde escaneos TCP y bloquea sondeos UDP no autenticados.
- **Revocación de credenciales en tiempo real**: La publicación inmediata de la CRL en el gateway termina sesiones al instante e impide nuevas conexiones, aislando terminales comprometidas sin afectar la operación del resto de los clientes.
- **Interconexión Site-to-Site transparente**: La integración de la sucursal mediante enrutamiento interno permite el consumo directo de los microservicios sin VPN instalado en los clientes finales.



Muchas gracias